

CO5 – Assessment Tool 2

Name: Pranov Raaj G

Reg No: 192372355

Question 1 – Legacy Windows RPC Vulnerabilities

The scenario describes exposed Windows RPC services caused by delayed patching in a financial organization. According to the assessment, the task is to evaluate attacker exploitation, assess patch-delay risk, justify the response strategy, and recommend mitigations.

How attackers abuse exposed RPC

- Attackers identify RPC endpoints that remain accessible on legacy servers.
- Known RPC vulnerabilities may allow unauthorized remote execution or authentication bypass on unpatched systems.
- Once a single machine is compromised, stolen credentials can be reused for lateral movement across Active Directory.
- Privilege escalation becomes easier if vulnerable services run with SYSTEM or administrator privileges.

Attack chain

- Reconnaissance
- Service identification
- Vulnerability validation
- Initial access
- Credential theft
- Lateral movement
- Privilege escalation

Risk assessment

- Financial organizations handle sensitive customer and banking data.
- Delayed patching increases ransomware and compliance risks.
- One compromised server can expose multiple connected systems.

Recommended approach

Critical internet-facing systems require emergency patching, while business-critical internal servers should follow accelerated maintenance windows after testing.

Mitigations

- Disable unused RPC services
- Restrict RPC through Windows Firewall

- Network segmentation
- Multi-factor authentication
- Continuous monitoring
- Regular backups
- Vulnerability scanning

Illustrative Lab Observation

Illustrative lab command: `nmap -sV <server-ip>`

Run Comment: Service detection identifies exposed RPC-related services for defensive validation in an authorized environment.

Illustrative lab command: `rpcdump.py <server-ip>`

Run Comment: Enumerating registered RPC endpoints helps defenders verify unnecessary exposed interfaces during security assessment.

Question 2 – Web Application Security (XSS, CSRF & Session Management)

The application contains multiple weaknesses that attackers can combine into chained attacks.

Combined attack

- XSS executes malicious JavaScript inside the victim's browser.
- Session identifiers may be stolen when cookies are poorly protected.
- CSRF performs unauthorized actions using an authenticated session.
- Weak session handling allows attackers to reuse compromised sessions.

Impact

- Account takeover
- Unauthorized transactions
- Financial fraud
- Customer trust loss

Layered security

- Input validation
- Output encoding
- CSRF tokens
- HttpOnly cookies
- Secure & SameSite flags
- HTTPS
- Session timeout
- Content Security Policy

Illustrative Lab Observation

Illustrative lab command: curl -I <https://example.com>

Run Comment: Defenders verify whether Secure, HttpOnly, and SameSite cookie attributes are properly configured.

Illustrative lab command: OWASP ZAP passive scan

Run Comment: Passive scanning helps identify missing security headers and session-management weaknesses without exploiting users.

Question 3 – Outdated IIS Server

Detailed Answer

The enterprise continues using an outdated IIS server despite vulnerability warnings.

Possible attacker actions

- Exploit publicly known IIS vulnerabilities.
- Upload malicious web shells after successful compromise.
- Execute remote code and access application files.
- Move deeper into the internal network.

Risk evaluation

- Customer data exposure
- Website compromise
- Service downtime
- Regulatory penalties

Recommended strategy

Immediate patching is preferred for internet-facing systems. If patching cannot happen instantly, temporary isolation should reduce exposure until maintenance is completed.

Illustrative Lab Observation

Illustrative lab command: nmap -sV --script http-title <server-ip>

Run Comment: Service detection and banner identification help defenders inventory outdated IIS versions.

Illustrative lab command: nikto -h <http://<server-ip>>

Run Comment: Security teams use vulnerability scanning to identify outdated configurations before remediation.

Question 4 – Mobile Application Security

Detailed Answer

The application stores sensitive information in plaintext and communicates without secure encryption.

Attack possibilities

- Plaintext credentials may be extracted from device storage.
- Attackers on insecure Wi-Fi may intercept traffic.
- Unencrypted communication may be modified during transmission.

Impact

- Identity theft
- Account compromise
- Privacy violations
- Reputation damage
- Legal consequences

Secure implementation

- Android Keystore or iOS Keychain for credential storage.
- TLS/HTTPS with certificate validation.
- Certificate pinning for stronger trust.
- Encrypted SharedPreferences and SQLCipher.

Illustrative Lab Observation

Illustrative lab command: adb shell ls /data/data/<package>

Run Comment: Authorized testing can verify whether sensitive files are stored securely.

Illustrative lab command: adb logcat

Run Comment: Developers review logs to ensure credentials and tokens are not accidentally exposed.

Question 5 – Windows Firewall Disabled

Detailed Answer

Disabling the Windows Firewall temporarily creates a window where previously blocked services become reachable.

How attackers exploit it

- Perform network port scanning.
- Identify exposed services.
- Attempt unauthorized authentication.
- Move laterally after initial access.

Risk assessment

- Expanded attack surface
- Unauthorized access
- Lateral movement
- Operational disruption

Administrative safeguards

- Group Policy enforcement
- Automatic firewall restoration
- Security alerts
- Configuration monitoring
- Time-limited administrative changes